Кейс №3. Онлайн-чаевые: платформа для ресторанов

Проблематика и бизнес-контекст

- **Заказчик:** Сеть ресторанов «Вкус-Сервис» (20 заведений, 60 официантов).
- **Проблема:** более 85% гостей платят безналично — официанты теряют чаевые из-за отсутствия наличных у клиентов.
- **Рынок:** в РФ ниша занята («Нетмонет», «ВТБ.Чаевые», «SberTips»), но рынок **Юго-Восточной Азии (ЮВА)** свободен и перспективен для масштабирования.
- **Решение:** CRM-платформа безналичных чаевых по одноразовому QR на чеке с криптозащитой HMAC-SHA256 и мгновенной отчётностью.

Команда проекта (ветка `team_1_case_3`)

Участник	Роль	Зона ответственности
Иванов И.	Аналитик	Правила Q-1..Q-6, P-1..P-4, FR/NFR, Тесты Т3-1..Т3-5
Петрова А.	Архитектор / ИБ	Data Dictionary (22 поля), ER-модель, Угрозы ИБ, RBAC
Сидоров П.	Разработчик	CLI `04_прототип.py`, HTTP API `app_server.py`, OpenAPI
Кузнецова М.	Презентатор	Роли, 4 экрана диалога, Отчётность, Презентация и PDF

Требования (FR / NFR) и Ролевая модель (RBAC)

Ключевые FR и NFR (`04_requirements.md`)

- **FR-1..FR-3:** Генерация и валидация QR (HMAC, TTL 24ч, nonce), 4-экранный диалог выбора чаевых (0..50%).
- **FR-4..FR-6:** Идемпотентная оплата (`idempotency_key`), эмулятор шлюза, отмена только из `CREATED`.
- **FR-7..FR-10:** Регистрация с проверкой Админом, RBAC, 3 разреза отчётов, журнал `AuditEvent`.
- **NFR-1..NFR-6:** Проверка HMAC ≤ 50 мс (факт < 1 мс), маска реквизитов `****NNNN`, запрет PAN/CVV, Rate Limit 30 req/min.

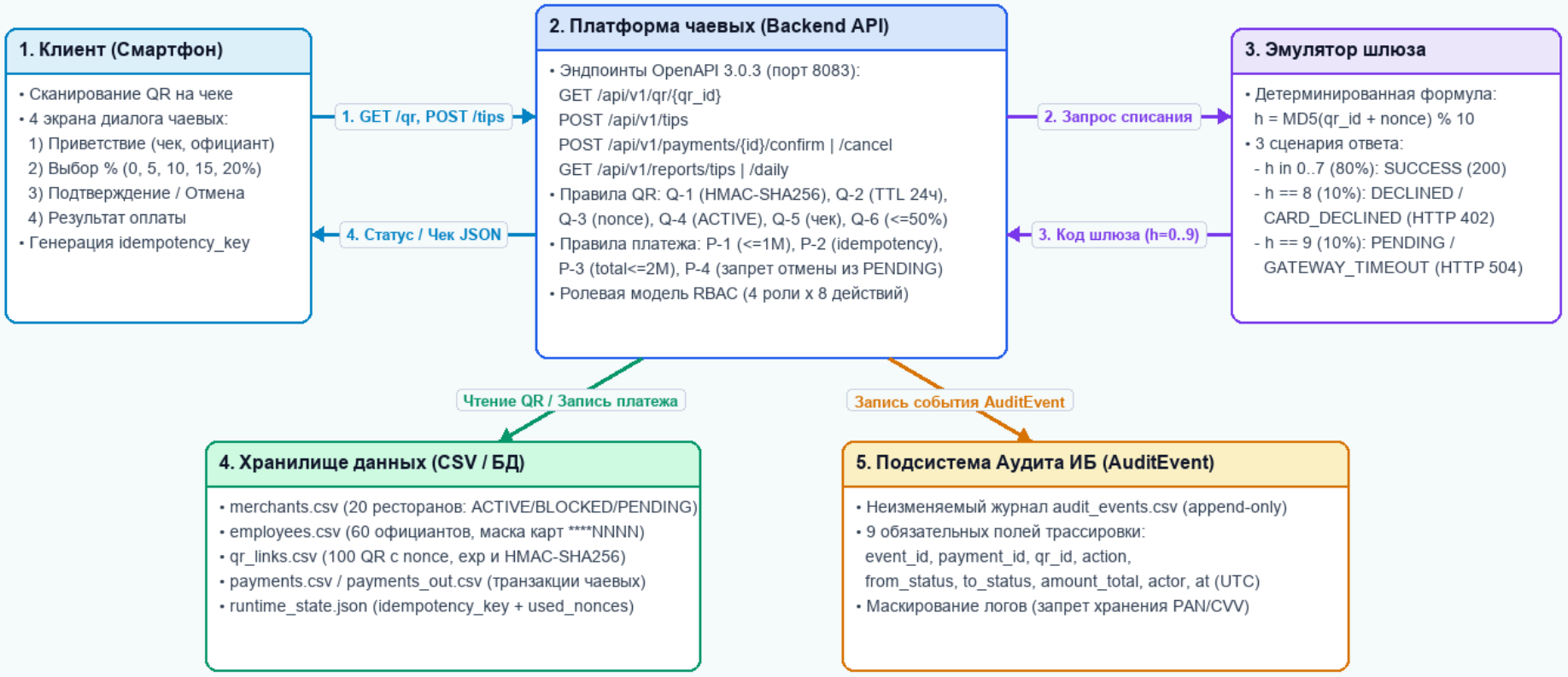
Матрица прав доступа RBAC (4 роли × 8 действий)

Действие	Мерчант	Официант	Клиент	Админ
Регистрация в платформе	да (PENDING)	по инвайту	нет	нет
Генерация QR на чек	да	да (свои)	нет	нет
Просмотр своих чаевых	да	только свои	нет	аудит
Сканирование QR	нет	нет	да (свой чек)	проверка
Оплата чаевых	нет	нет	да	нет
Отчёт по заведению	да (свой)	нет (403)	нет	да (все)
Блокировка мерчанта	нет	нет	нет	да
Изменение справочников	свои сотр.	нет	нет	да

Системная архитектура и Потоки данных

A.1. Архитектура платформы онлайн-чаевых «Вкус-Сервис» (Кейс 3)

Потоки данных: Клиент -> Платформа (REST API + Валидация Q-1..Q-6 / P-1..P-4) -> Эмулятор шлюза -> Хранилище -> Аудит



Модель данных (ER) и Правила QR / Платежа

ER-модель (6 сущностей, связи 1:N)

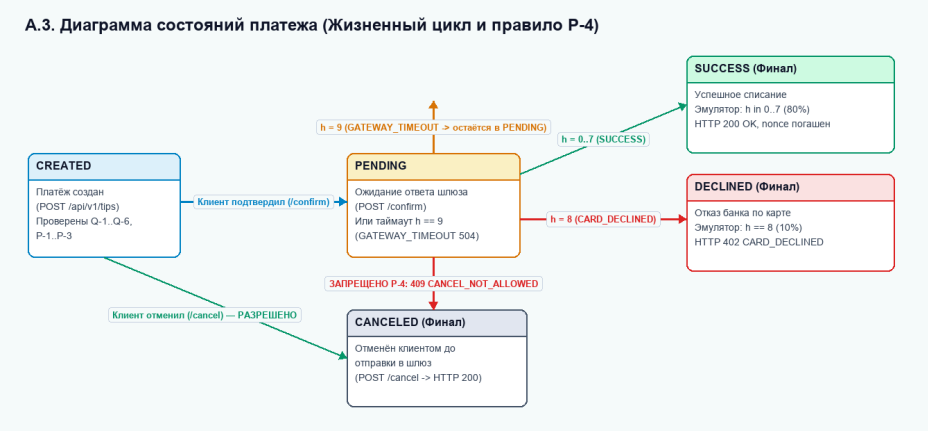


Правила валидации QR (Q-1..Q-6) и платежа (P-1..P-4)

ID	Правило / Условие	HTTP	Код ошибки
Q-1	`signature == HMAC-SHA256(SECRET, payload)[:16]`	422	`INVALID_QR`
Q-2	`exp >= now` (TTL = 24 часа)	410	`QR_EXPIRED`
Q-3	Одноразовый nonce ещё не погашен	409	`QR_USED`
Q-4	`merchant.status == ACTIVE`	403	`MERCHANT_BLOCKED`
Q-5	`receipt_id` совпадает с QR чека	422	`RECEIPT_MISMATCH`
Q-6	`0 <= tip_pct <= 50` (`tip <= 0.5*amount`)	422	`TIP_OUT_OF_RANGE`
P-1	`0 < base_amount <= 1 000 000`	422	`AMOUNT_OUT_OF_RANGE`
P-2	Повтор `idempotency_key` → возврат созданного	200	— (без дубля в CSV)
P-3	`amount_total <= 2 000 000`	422	`AMOUNT_OUT_OF_RANGE`
P-4	Запрет отмены из `PENDING` / `SUCCESS`	409	`CANCEL_NOT_ALLOWED`

Жизненный цикл платежа, Диалог и Отчётность

Граф состояний платежа и эмулятор шлюза



Отчётность по реальному `payments.csv` (`09_reports.md`)

- **1. По мерчанту `m_001`:** 6 платежей (5 `SUCCESS`, 1 `DECLINED`), `tips_total = 414.85 ₽` (по всем 611.20 ₽), `avg_tip_pct = 9.0%` (10.0% все), `success_rate = 0.8333`.
- **2. По официанту `e_001` (Иванов И.):** `tips_total = 83.60 ₽` (`31.85 + 51.75`), `payments_count = 2`, `avg_tip_amount = 41.80 ₽`, `top_day = "2025-11-03"`.
- **3. По дням `m_001`:** `2025-11-01` → `245.90 ₽` (3 чека, сред. `10.0%`); `2025-11-03` → `168.95 ₽` (2 успешных чека, сред. `7.5%`).

4 экрана клиентской формы

- **Экран 1:** Приветствие (ресторан, официант, сумма чека) → **Экран 2:** Выбор % (0, 5, 10, 15, 20%) → **Экран 3:** Подтверждение / Отмена → **Экран 4:** Результат (SUCCESS / DECLINED / TIMEOUT).

Демонстрация работы прототипа (04_прототип.py)

Terminal — python 04_прототип.py (qr_001, qr_003, --run-tests)

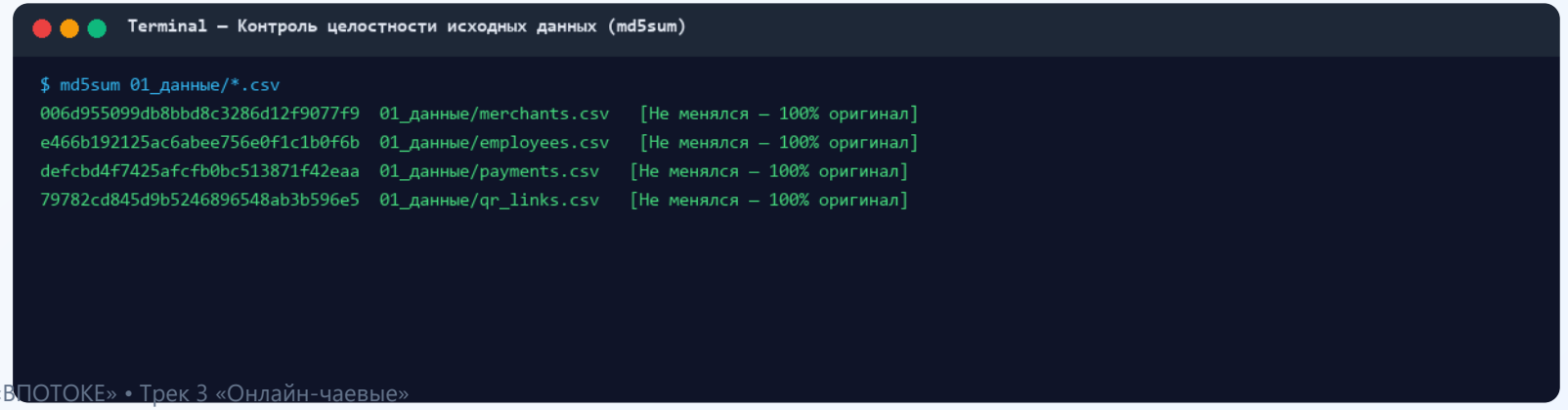
```
$ python 04_прототип.py qr_001.json
{
  "payment_id": "p_demo_001",
  "status": "SUCCESS",
  "amount_total": 668.85,
  "tip_amount": 31.85,
  "error_code": null
}

$ python 04_прототип.py qr_003.json
{
  "payment_id": "p_demo_003",
  "status": "DECLINED",
  "amount_total": 1047.65,
  "tip_amount": 136.65,
  "error_code": "CARD_DECLINED"
}

$ python 04_прототип.py --run-tests
======================================================================
РЕЗУЛЬТАТЫ АВТОМАТИЧЕСКОГО ПРОГОНА 5 ТЕСТ-СЦЕНАРИЕВ (КЕЙС 3)
======================================================================
Т3-1 (Успех)                    | PASS [ДА] | {"payment_id": "p_demo_001", "status": "SUCCESS", "amount_total": 668.85}
Т3-2 (Отказ шлюза)              | PASS [ДА] | {"payment_id": "p_demo_003", "status": "DECLINED", "error_code": "CARD_DECLINED"}
Т3-3 (Неверный QR)              | PASS [ДА] | {"status": "ERROR", "error_code": "INVALID_QR", "http_status": 422}
Т3-4 (Повтор / Идемпотентность) | PASS [ДА] | {"payment_id": "p_demo_002", "status": "SUCCESS", "idempotent_replay": true}
Т3-5 (Отмена платежа)           | PASS [ДА] | {"cancel_from_created": "CANCELED", "cancel_from_pending": "CANCEL_NOT_ALLOWED (409)"}
======================================================================
```

Доказательство качества: 5 тест-сценариев

ID	Тест-сценарий	Входные данные	Ожидаемый результат	Фактический результат (04_прототип.py / test_case3.py)	Статус
T3-1	Успешная оплата	qr_001, base=637.00, tip_pct=5	SUCCESS, total=668.85, tip=31.85	status="SUCCESS", amount_total=668.85, tip_amount=31.85 (HTTP 200)	**PASS**
T3-2	Отказ шлюза	qr_003, base=911.00, tip_pct=15	DECLINED, CARD_DECLINED	status="DECLINED", error_code="CARD_DECLINED", total=1047.65 (HTTP 402)	**PASS**
T3-3	Неверный / истёкший QR	qr_001 (битая подпись / now > exp)	INVALID_QR (422) / QR_EXPIRED (410), без записи	Получены 422 INVALID_QR и 410 QR_EXPIRED, в payments_out.csv 0 новых строк	**PASS**
T3-4	Повтор (Идемпотентность)	qr_002, один idempotency_key дважды	Тот же payment_id, 1 строка в CSV	Оба вызова вернули p_demo_002 (HTTP 200), в payments_out.csv ровно 1 строка	**PASS**
T3-5	Отмена платежа	qr_004 (из CREATED), qr_010 (из PENDING)	Из CREATED → CANCELED; из PENDING → 409	Из CREATED → CANCELED (200); из PENDING → 409 CANCEL_NOT_ALLOWED	**PASS**



Информационная безопасность, Риски и Итоги

Модель угроз и меры защиты (11_ИБ.md)

ID	Угроза ИБ	Мера предотвращения (Mitigation)	Риск
U-1	Подделка QR на чеке	HMAC-SHA256 + ключ в os.environ + compare_digest	Низкий
U-2	Повторная оплата (Replay)	Одноразовый nonce (6 hex) + TTL = 24 ч (Q-2, Q-3)	Низкий
U-3	Утечка карт / реквизитов	Запрет хранения PAN/CVV; маска ****NNNN (****1001)	Низкий
U-4	Двойное списание средств	idempotency_key (P-2) + запрет отмены из PENDING	Низкий
U-5	Манипуляции официанта	Привязка к receipt_id (Q-5), лимит чаевых ≤ 50% (Q-6)	Низкий
U-6	Отсутствие трассировки	Журнал AuditEvent (9 полей на каждый переход статуса)	Низкий

Жизнеспособность и масштабирование в ЮВА

- **Полная готовность MVP:** реализованы CLI-прототип, веб-сервер OpenAPI 3.0.3, 4-экранный интерфейс и 100% автотестов на базовом стеке Python.
- **Готовность к рынку ЮВА:** архитектура адаптера шлюза позволяет без изменения ядра подключить национальные QR-системы ЮВА (PromptPay, QRIS, VietQR, PayNow).
- **Git-репозиторий и ветка:** https://github.com/lol157/vpotoke-case3-online-tips (ветка team_1_case_3).

